Kromel Dikey Süt Soğutma Tankı

LAB 1: Safety Architecture

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?

Dikey süt soğutma tankındaki temel tehlike 25W gücündeki karıştırıcı kanat motorudur. İnsanlar, süt numunesi alırken veya tankı manuel yıkarken dönen paslanmaz çelik kanatlara elini/kolunu kaptırması sonucu mekanik çarpma, ezilme ve kopma gibi zararlar görebilir (ISO 12100 tehlike türleri)

2. Safety function (emniyet fonksiyonu) hangisidir?

Tank kapağı açıldığında sistemin (karıştırıcı ve soğutucu) otomatik olarak devre dışı kalmasıdır (Kapak Interlock fonksiyonu)

3. Safety-related control system nerede?

Tank kapağı menteşesindeki emniyet siviçi (sensör), bu sensörün sinyalini değerlendiren emniyet kontrolcüsü (Safety PLC/Röle) ve motor enerjisini kesen kontaktör (aktüatör) ayrı bir safety yolunda (emniyet kumandasında) bulunur

4. Normal PLC ile Safety PLC farkı nedir?

Tanktaki normal elektronik kontrol kartı (PLC) süt sıcaklığını ve karıştırma döngüsünü (3 dk çalış 10 dk dur) üretim süreçleri için yönetir. Safety PLC ise üretim verimliliğine bakmaksızın, sadece insana zarar gelmemesi (kapak açılınca motorun hemen durması) için ayrı bir yolda, yüksek güvenilirlikte (fail-safe) çalışır.

5. PLr/SIL neden var? Bu fonksiyon için neden önemli?

Kapak açıldığında motorun kesinlikle duracağının garanti edilebilmesi, yani güvenilirliğinin riskle orantılı olarak ispatlanması için vardır. Dönme hızı ve mekanik güç nedeniyle uzuv ezilmesi riski yüksek olduğu için emniyet devrelerinin hata yapmadan (doğrulanmış olarak) çalışması hayati önem taşır.

6. Safe state (güvenli durum) nedir?

Karıştırıcı motorun enerjisinin sistem tarafından tamamen kesilmiş olduğu ve mekanik kanatların tamamen durduğu durumdur.

7. Safety function hangi dijital bağımlılıklara sahip?

Safety PLC veya rölenin yazılımındaki yapılandırılmış tepki/durdurma sürelerine ve varsa HMI üzerinden gönderilebilecek bir "bakım onayı/bypass" parametresine bağımlı olabilir.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?

Ağa bağlı elektronik kontrol kartına uzaktan sızılıp, kapak emniyet siviçinin sinyalini veya sensör eşik değerlerini bypass edecek (force) bir parametre değişikliği yapılırsa bu koruma fonksiyonu bozulur.

LAB 2: IEC 62443 Mini Workshop

Görev A: Varlıkları bölgelere ayırın

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Elektronik kontrol kartı (Normal PLC), dijital ısı göstergesi ve karıştırıcı/kompresör motor sürücüleri "Kontrol (Saha) Bölgesi"nde yer alır. Uzak erişim modülü "Dış Bağlantı Bölgesi"ndedir.

2. Safety PLC'yi hangi bölgeye koydunuz - neden?

Ayrı bir "Emniyet Bölgesi (Safety Zone)" içine koydum. Çünkü normal PLC ağı ele geçirilse veya çökse bile emniyet fonksiyonunun (kapak siviçi) bundan etkilenmeden çalışmaya devam etmesi için izole kalması gerekir.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Dış Ağdan HMI/SCADA ağına geçiş kapısında VPN tünel ve MFA (kimlik) kontrol edilecek. Bu bölgeden Kontrol (PLC) bölgesine geçişte ise firewall kuralı ile segmentasyon sağlanıp yalnızca yetkili reçete komutları (örn. hedef sıcaklık parametresi) kontrol edilecek.

Görev B: Uzak erişim kararı

Karar	Seçenekler	Seçiminiz + Nedeni
Aracı	Doğrudan / Jump server	Jump server (Saldırganın doğrudan kontrol ağına ve makineye inmesini engellemek için)
Tünel	Açık / VPN	VPN (Makine ile uzak bağlantı arasındaki trafiği şifrelemek için)
Kimlik	Parola / MFA	MFA (Paylaşılan veya çalınan parolalara karşı kesin bir önlem sunmak için)
Hesap	Paylaşılan / Kişisel	Kişisel (Kimin hangi değişikliği yaptığını ve loglarını birebir izleyebilmek için)
Kayıt	Yok / Tam oturum kaydı	Tam oturum kaydı (Olay anında CRA bildirim süreçleri, zaman çizgisi ve kök neden analizine kanıt bırakması amacıyla)
Zamanlama	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı (Açık kapı bırakmamak, erişimi sadece bakım ihtiyacında yetki ile açmak için)

LAB 3: Threat & Risk + Risk Matrix

Görev: Üç senaryo kurun ve puanlayın

Senaryo (Kim, kapı, zincir, fiziksel sonuç)	L	S	E	Skor	Öncelik
Fırsatçı dış saldırgan, internete açık erişim modülü üzerinden girer	3	3	3	27	Kritik

ve Safety PLC bypass parametresini aktif eder. Kapak açılsa dahi karıştırıcı motor durmaz; manuel yıkama yapan operatörün eli/kolu kanatlara sıkışır (ezilme, kopma)					
Meraklı içeriden (şirket personeli), HMI panelindeki paylaşılan şifre ile girer, soğutma tankının hız veya bakım modunu yanlışlıkla açar. Kapak açıldığında karıştırıcı yavaşlamaz ve bakımcıya çarparak ağır yaralar.	3	3	1	9 (S3)	Yüksek (S3)
Hedefli saldırgan (tedarikçi/servis ağı üzerinden), ofis ağından sızarak PLC ısı sensör verisini değiştirir ve kompresörü limitsiz çalışmaya zorlar. Kompresör aşırı yükte çalışıp patlar, yanındaki işçiler ciddi zarar görür.	1	3	2	6 (S3)	Orta (S3)

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

1. Senaryo (Kritik - Skor 27). Çünkü sistem doğrudan dış internete açık (E=3), parola gibi zayıf bir giriş var (L=3) ve emniyetin baypas edilmesi halinde sonucu ölüm/uzuv kopmasına (S=3) yol açıyor

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet, 3. Senaryo (Skor 6). L=1 ve E=2 olduğu için skoru düşük (Orta) çıkmıştır; fakat fiziksel sonuç kompresör patlaması (S=3) olduğu için "S3 kuralı" gereği S3 bayrağı ile işaretlenmiş ve Risk Register tablosunda ayrı/görünür olarak konumlandırılmıştır.

LAB 4: Secure Remote Access

Görev A: Mevcut ve Hedef

MEVCUT: Doğrudan internete açık, statik IP ve yönlendirilmiş port üzerinden paylaşılan zayıf şifre (admin/1234 vs.) ile ulaşılan, izleme kaydı tutulmayan, sürekli ve kontrolsüz açık ağ yapısı.

HEDEF: Doğrudan erişimin kapatılıp Jump Server arkasına alındığı, VPN tüneli üzerinden şifrelenmiş, her bir servis teknisyeni için Kişisel Hesap ve MFA kurulan, işlem anında açılıp bitince kapatılan (varsayılan kapalı) ve Tam Oturum Kaydı tutulan güvenli ağ mimarisi

Görev B: Functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Etkilenmez. Çünkü "Kapak açıldığında motorun durması" şeklindeki can güvenliği fonksiyonu, ağa bağlı genel elektronik kontrol kartından ayrı olarak donanımsal güvenlik rölesi (Safety Relay) ile fiziksel bir kilit sistemi (interlock) olarak kurgulanmıştır. Siber ağ yolu, fiziksel safety hattına asla ulaşamaz.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

Tank kapağına ait interlock (durdurma) emniyet fonksiyonu; uzaktan kontrol edilebilen, süt sıcaklığını veya motor döngülerini yöneten PLC kontrol sistemindeki herhangi bir siber değişiklik, manipülasyon, donma veya haberleşme kaybı durumunda tamamen izole, öncelikli ve bağımsız olarak aktifleşebilmelidir.